

SIMATS ENGINEERING

ASSESSMENT TOOL 2

Name	SHIAK REEHAN
Register Number	192565071
Date	
Time	1hr

COURSE NAME: Cybersecurity Incident Handling And Response

COURSE CODE: CSA60

COURSE OUTCOME COVERED

CO3: *Assess incident identification processes using monitoring systems, log analysis, threat intelligence, detection mechanisms to verify incidents, classify threats, assess their impact. (BL2, BL3)*

Activity Tool : IOC Identification and Threat Hunting Analysis (Medium)

Assessment Tool Weightage: 20%

Code of Conduct:

I _____ Shaikreehan192565071_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Shaik Reehan

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
IOC Identification and Analysis	25%	Accurately identifies and thoroughly analyzes relevant IOCs such as IP addresses, domains, URLs, file hashes, suspicious processes, and abnormal activities, with clear justification.	Identifies and analyzes most relevant IOCs with minor omissions or limited justification.	Identifies some IOCs but provides limited or incomplete analysis.	Unable to identify relevant IOCs or explain their significance.
Threat Hunting Methodology	25%	Develops a systematic threat-hunting approach using hypotheses, data collection, searching, analysis, investigation, and appropriate response actions.	Applies a suitable threat-hunting process with minor gaps in methodology or sequencing.	Demonstrates basic threat-hunting activities but lacks a systematic approach.	Unable to demonstrate an appropriate threat-hunting methodology.
Use of Security Data and Correlation	20%	Effectively uses and correlates SIEM, EDR, IDS/IPS, network, host, authentication, and application data to identify hidden or suspicious activities.	Uses multiple security data sources and performs reasonable correlation with minor gaps.	Uses limited data sources with incomplete correlation.	Fails to use relevant security data or establish meaningful correlations.
Threat Intelligence, Anomaly and Behavioural Analysis	15%	Effectively integrates threat intelligence, anomaly detection, and behavioural analysis to identify sophisticated, unknown, or evolving threats.	Uses threat intelligence and behavioural/anomaly analysis appropriately with minor omissions.	Demonstrates limited understanding or application of these techniques.	Unable to apply threat intelligence, anomaly detection, or behavioural analysis effectively.
Investigation, Documentation, and Presentation	15%	Presents a clear, professional investigation with evidence, findings, attack sequence, conclusions, and appropriate recommendations supported by diagrams or workflows.	Provides well-organized documentation and reasonable findings with minor presentation or analytical issues.	Documentation is partially organized with limited evidence, analysis, or conclusions.	Documentation is incomplete, poorly organized, and lacks supporting evidence or meaningful conclusions.

1. SIEM Correlation and IOC Identification

Introduction

A coordinated attack usually consists of multiple stages rather than a single suspicious event. In this scenario, the sequence of **failed logins** → **unusual successful login** → **privilege escalation** → **suspicious process execution** → **external network connection** strongly suggests a possible attack chain.

A SIEM can correlate these events using **timestamps, usernames, source IP addresses, hostnames, process information, and network destinations** to determine whether the events are related.

Step 1: Analyze the Individual Events

Event	What to Investigate	Possible IOC
Multiple failed logins	Username, source IP, time, frequency	Source IP, username, login pattern
Successful unusual login	Location, device, IP, time	Unusual IP/location, account
Privilege escalation	Account, privilege gained, process responsible	Username, process, privilege change
Suspicious process	Process name, parent process, command line, hash	Process name, hash, executable path
External connection	Destination IP/domain, port, protocol	IP, domain, URL, port

Each event alone may have a legitimate explanation. However, their **sequence and relationship** can indicate compromise.

Step 2: Correlate the Events

The SIEM should first establish whether the events involve the **same user, host, source IP, or time period**.

For example:

10:01 → 20 failed login attempts against user01

↓

10:05 → Successful login to user01 from an unusual IP

↓

10:07 → user01 obtains administrator privileges

↓

10:09 → Unknown executable starts on the endpoint

↓

10:11 → Endpoint establishes an external connection

This sequence suggests:

Credential Attack → Account Compromise → Privilege Escalation → Execution → External Communication

The correlation becomes stronger if the same account, endpoint, IP address, process, or time window appears across multiple events.

Step 3: Identify and Validate IOCs

Potential IOCs should be extracted from the investigation.

Network IOCs

- Source IP address
- Destination IP address
- External domain
- URL
- Destination port
- Unusual protocol
- Repeated outbound connections

Host IOCs

- Suspicious process name
- Executable path
- Process hash
- Parent-child process relationship
- Unexpected file creation
- Persistence mechanisms

Authentication IOCs

- Username
- Multiple failed logins
- Unusual login location
- Unusual login time
- New device
- Privilege escalation

The IOC should not automatically be considered malicious. It should be **validated** against internal baselines and threat-intelligence sources.

Step 4: Use Multiple Security Data Sources

A strong investigation should correlate data from several sources.

SIEM

Provides the overall event timeline and correlation.

Authentication Logs

Determine whether credentials were attacked or compromised.

EDR

Provides:

- Process execution
- File hashes
- Parent-child processes
- Command-line arguments
- Endpoint connections

Firewall / Network Logs

Determine where the compromised system communicated.

IDS/IPS

Identify:

- Exploit attempts
- Malicious traffic
- Scanning
- Known attack signatures

Application/Server Logs

Determine whether the attacker accessed or modified applications and sensitive resources.

Step 5: Threat Intelligence Validation

The suspicious IP address, domain, URL, and file hash can be checked against trusted threat-intelligence sources.

For example:

Unknown process → SHA-256 hash → Threat-intelligence lookup

If the hash is associated with known malware, confidence in the incident increases.

Similarly:

External domain → Reputation/threat-intelligence check → Known C2 domain

This can provide additional evidence that the external connection is malicious.

Step 6: Determine Whether It Is a Coordinated Attack

The activity should be considered a likely coordinated attack when several independent indicators support the same conclusion.

For example:

Multiple failed logins were followed by a successful login from an unusual location. Shortly afterward, the account gained elevated privileges, a suspicious process executed on the endpoint, and the endpoint established an external connection to a suspicious domain.

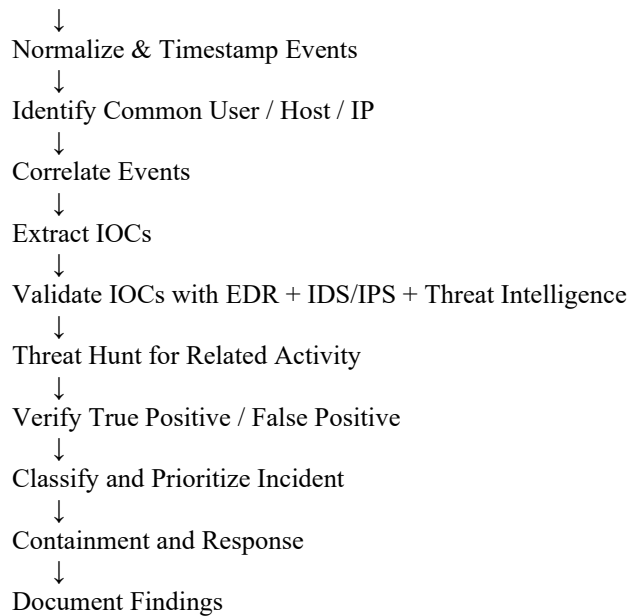
This sequence provides evidence of:

Initial Access → Credential Compromise → Privilege Escalation → Execution → Command-and-Control

The analyst should continue investigating for persistence, lateral movement, and possible data exfiltration.

Investigation Workflow

Security Events
↓
SIEM Collection



Conclusion

The events should not be investigated independently. **SIEM correlation connects authentication, endpoint, privilege, and network evidence into a single timeline.** By identifying and validating IP addresses, domains, hashes, processes, usernames, and abnormal activities, analysts can determine whether the events represent a coordinated attack and identify the attack sequence.

2. Anomaly Detection and IOC Identification

Introduction

An unusual increase in outbound traffic combined with an unknown process communicating with an unfamiliar external domain is a strong indicator that a server may have been compromised.

However, unusual activity does not automatically mean an attack. The investigation should combine **anomaly detection, behavioural analysis, IOC identification, threat intelligence, and systematic threat hunting**.

Step 1: Establish the Anomaly

First, compare the server's current network activity with its normal baseline.

For example:

Normal:

Server → 100 MB outbound traffic/day

Current:

Server → 5 GB outbound traffic/day

This significant increase becomes an **anomaly**.

The analyst should investigate:

- When did the increase begin?
 - Which process generated the traffic?
 - Which destination received the traffic?
 - Which port and protocol were used?
 - Is this normal for the server?
 - Were there recent software or configuration changes?
-

Step 2: Perform Behavioural Analysis

The unknown process should be examined using EDR/host telemetry.

Investigate:

- Process name
- Process ID
- Parent process
- Command-line arguments
- Executable location
- File creation time
- File hash
- User account running the process
- Network connections
- Child processes
- Persistence mechanisms

Example

Suppose the server normally runs:

`web_server.exe`

But an unfamiliar process appears:

`update_service.exe`

and it:

- Runs from an unusual directory
- Starts automatically
- Makes repeated external connections
- Transfers large amounts of data

This behaviour increases the likelihood of malicious activity.

Step 3: Identify IOCs

The investigation should extract as many relevant IOCs as possible.

Network IOCs

- Unfamiliar domain
- Destination IP
- URL
- Destination port
- DNS requests
- Connection frequency
- Outbound traffic volume

Host IOCs

- Unknown process
- File hash
- Executable path
- Parent-child process relationship
- Suspicious command line
- Newly created files
- Persistence mechanisms

Behavioural IOCs

- Abnormal outbound traffic
 - Periodic beaconing
 - Unusual data transfer
 - Communication outside normal working patterns
 - Unexpected process execution
-

Step 4: Use Threat Intelligence

The unfamiliar domain, IP address, and file hash should be checked against threat-intelligence sources.

For example:

```
Unknown Domain
↓
Threat Intelligence
↓
Known malicious?
↓
Yes → High-confidence IOC
No  → Continue investigation
```

A domain that is newly registered, associated with malware, or previously reported as command-and-control infrastructure would increase the confidence that the activity is malicious.

However, **absence from threat-intelligence databases does not prove that an IOC is safe.** Attackers may use newly created or previously unknown infrastructure.

Step 5: Develop a Threat-Hunting Hypothesis

Threat hunting should be **hypothesis-driven**.

Hypothesis

"The server may be compromised and the unknown process may be communicating with an external command-and-control server."

The analyst then searches security data to prove or disprove this hypothesis.

Step 6: Conduct Systematic Threat Hunting

1. Search DNS Logs

Look for:

- First-seen domains
- Repeated DNS queries
- Suspicious domains
- Unusual DNS patterns

2. Search Firewall/Network Logs

Look for:

- Destination IP
- Destination port
- Connection frequency
- Amount of data transferred
- Other systems communicating with the same destination

3. Search EDR Data

Look for:

- Same process on other systems
- Same file hash
- Similar command lines
- Parent-child process relationships
- Suspicious persistence

4. Search SIEM

Search for the identified IOC across historical logs.

For example:

IOC: suspicious-domain.example

Search:

DNS + Firewall + Proxy + EDR + Application logs

If multiple systems contacted the same domain, the incident may be broader than the original server.

Step 7: Correlate the Evidence

Suppose the investigation produces:

Evidence	Finding
Network	Large outbound traffic
EDR	Unknown process
DNS	Unfamiliar domain
Firewall	Repeated external connections
Threat Intelligence	Domain associated with malicious activity
File analysis	Suspicious file hash
SIEM	Same IOC observed previously

The evidence now supports a strong conclusion that the server may be compromised.

Possible attack chain:

Initial Compromise → Malicious Process → C2 Communication → Data Transfer

Step 8: Verify the Incident

Before declaring a confirmed incident, analysts should determine whether there is a legitimate explanation.

Check:

- Scheduled backups
- Software updates
- Cloud synchronization

- Administrative maintenance
- Legitimate external APIs
- Recent application changes

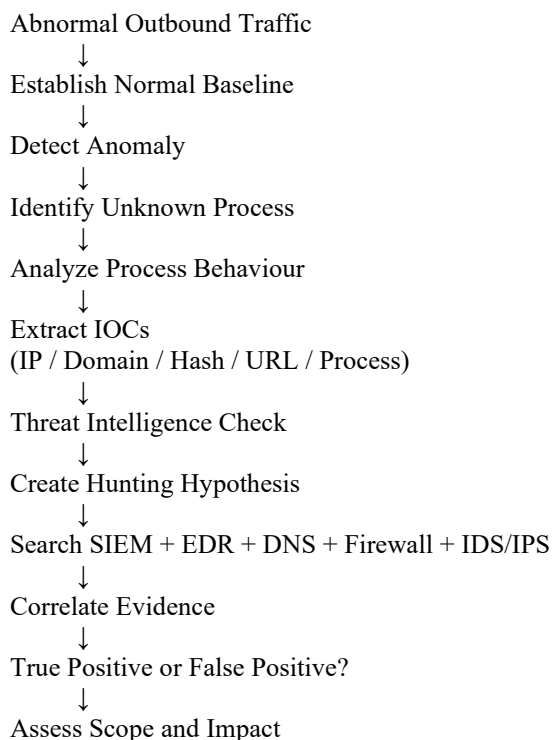
If no legitimate explanation exists and multiple independent indicators support malicious activity, classify the event as a **true positive**.

Step 9: Response Actions

If malicious activity is confirmed, appropriate actions may include:

1. Isolate the affected server.
 2. Block the malicious domain/IP.
 3. Terminate the malicious process.
 4. Preserve forensic evidence.
 5. Identify affected accounts.
 6. Search other systems for the same IOCs.
 7. Remove persistence mechanisms.
 8. Reset compromised credentials where necessary.
 9. Monitor for recurrence.
 10. Document the complete incident.
-

Complete Threat-Hunting Workflow



↓
Contain + Eradicate + Monitor
↓
Document Findings

Conclusion

Anomaly detection identifies **what is unusual**, while behavioural analysis determines **what the process is actually doing**. IOC identification provides specific evidence such as domains, IP addresses, hashes, and processes. Threat intelligence helps determine whether those indicators are already associated with known threats, while threat hunting searches the organization's environment for additional evidence.

Together, these techniques provide a systematic approach for discovering **unknown or evolving threats**, validating the incident, determining its scope, and supporting an effective response.